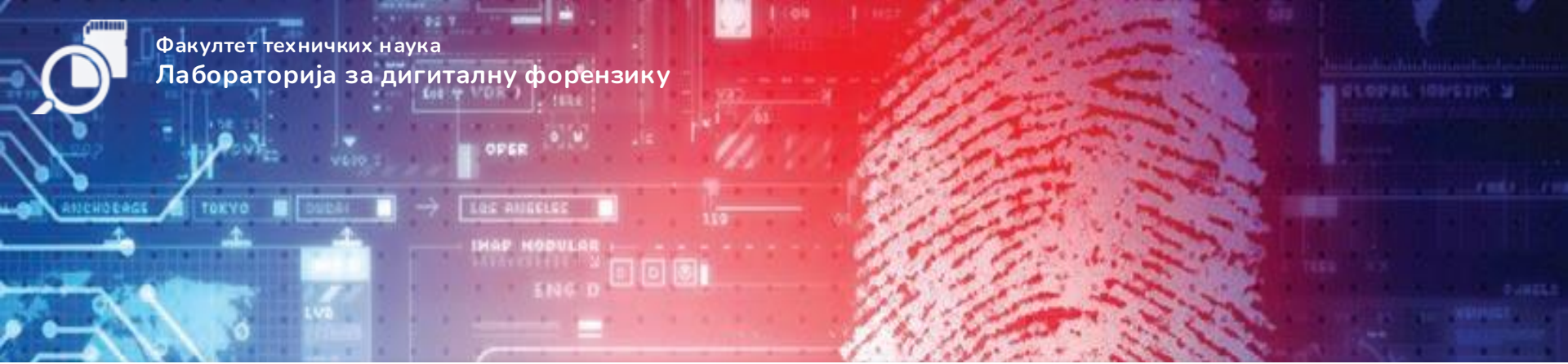


Факултет техничких наука
Лабораторија за дигиталну форензику

ФОРЕНЗИКА МОБИЛНИХ УРЕЂАЈА



Увод у дигиталну форензику

Милица Матијевић Гостојић, Светлана Томић

Преглед области

Чиме се бави форензика мобилних уређаја?

Форензика мобилних уређаја је област дигиталне форензике чији предмет су докази ускладиштени на мобилним уређајима или преношени путем целуларне мреже.

Које све доказе можемо прикупити?

- ➔ Дневници комуникација и листе контаката
- ➔ Календари и подсетници
- ➔ SMS, MMS, истант поруке (Viber, WhatsApp, Messenger итд.)
- ➔ Електронска пошта
- ➔ Прегледање интернета
- ➔ Фотографије и видео снимци
- ➔ Документа
- ➔ Локација и кретање корисника итд.

Преглед области

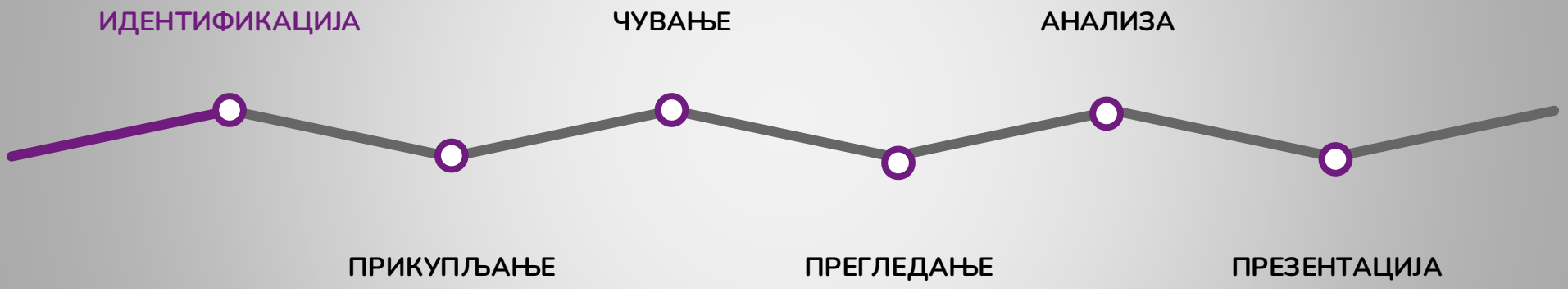
Зашто је значајна?

- ➔ Мобилни уређаји су увек поред корисника
- ➔ Преносиви су
- ➔ Користе целуларну мрежу
- ➔ Користе се интимније и чешће него рачунари
- ➔ Користе се за шири спектар потреба
- ➔ Већа заступљеност
- ➔ Новији телефони представљају компактне рачунаре
- ➔ Садрже велику количину информација

Шта представља изазов?

- ➔ Мноштво хардверских архитектура, оперативних система, апликација, произвођача
- ➔ Безбедносне функције мобилне платформе
- ➔ Криптографска заштита на различитим слојевима архитектуре
- ➔ Удаљено брисање или измена података (уређај је бежично повезан са интернетом)
- ➔ Закључавање екрана
- ➔ Комуникација преко целуларне мреже (подаци се уз наредбу суда могу добити од мобилног оператора)

Процес форензичке истраге



Напомена – етапе форензичке истраге не одвијају се секвенцијално. Често су репетитивне.

Идентификација

Односи се на детектовање, препознавање и одређивање дигиталних уређаја које треба истражити.

Примери: мобилни уређај, таблет, SIM картица, SD картица, документација о месту догађаја (фотографије, видео снимци, гласовни снимак), просторија у којој се налази уређај, стање уређаја, књиге, белешке, каблови...

Под идентификацијом се подразумева и очитавање идентификатора дигиталних уређаја, који се истражују (произвођач, модел, серијски број, идентификатор у мрежи).

- ➔ **Mobile Equipment Identifier (MEID)** – глобално јединствен идентификатор за уређаје у CDMA (2G) мрежи
- ➔ **International Mobile Station Equipment Identity (IMEI)** – глобално јединствен идентификатор за уређаје у GSM (2G), UMTS, (3G), LTE (4G) мрежи.
- ➔ **Subscriber Permanent Identifier (SUPI)** – 5G (шифрован SUCI)

Идентификација

Произвођач: Google
Модел: Nexus 7
Оперативни систем: Android
Верзија ОС: 5.1.1
Серијски број: 015d2ea4ab441a0f
IMEI: 358240005111110



Напомена:

- ➔ Демонстрација је везана за Android оперативни систем.
- ➔ За потребе вежби користићемо таблете које имамо у лабораторији за дигиталну форензику

Идентификација

Произвођач: Google
Модел: Pixel 5
Оперативни систем: Android
Верзија ОС: 6.0
Серијски број: 009d2za4ab671b0f
IMEI: 352740935231139 8

Остале спецификације се могу пронаћи на линку



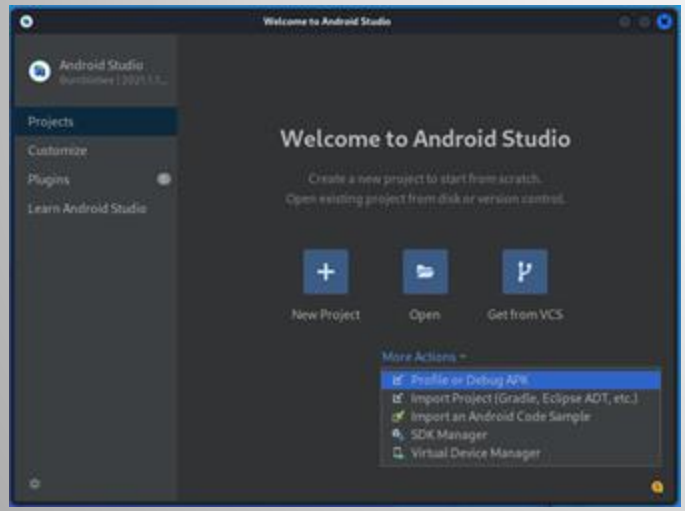
Напомена:

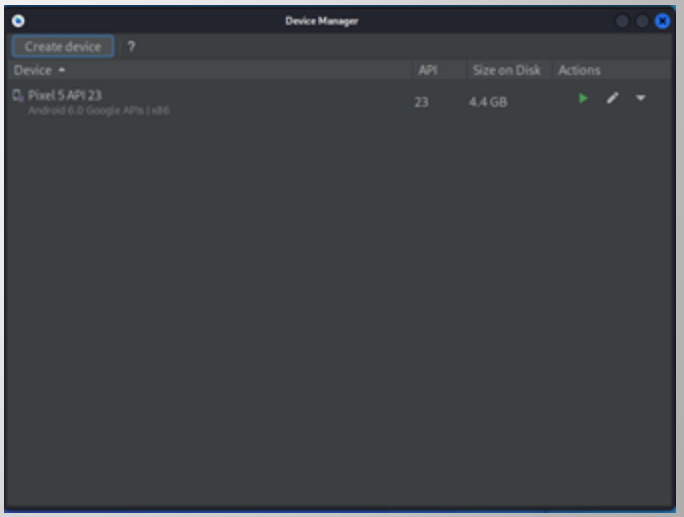
- ➔ Демонстрација је везана за Android оперативни систем.
- ➔ За потребе вежби користићемо Android Emulator како бисмо симулирали мобилни уређај

Идентификација

Android Emulator - покретање преко GUI-а Android Studio-а

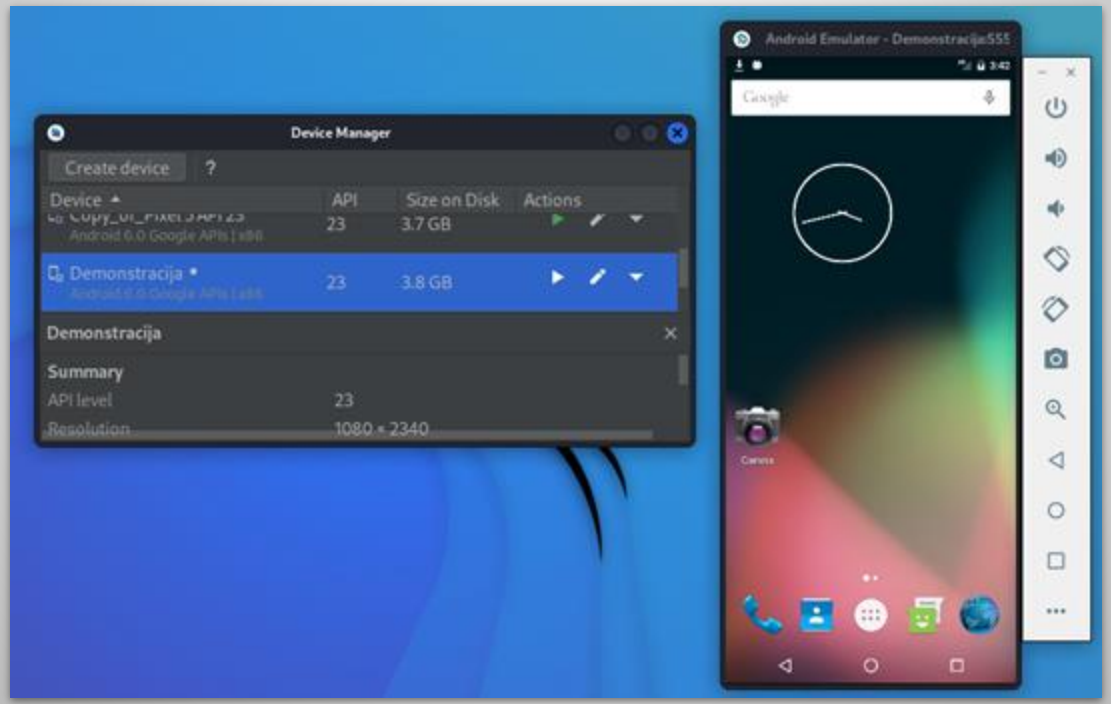
1. У оквиру менија куцамо Android Studio и покренемо
2. Одаберемо опцију MoreActions, па одаберемо опцију Virtual Device Manager
3. Креирамо уређај и покренемо га на зелену стрелицу



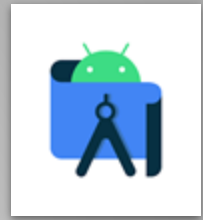


Идентификација

Android Emulator - покретање преко GUI-а Android Studio-а



Идентификација



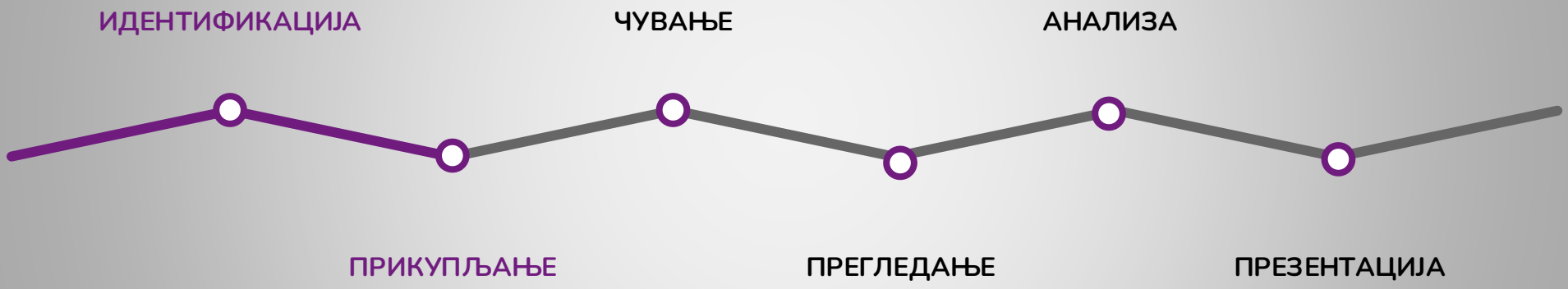
Android Emulator - покретање помоћу терминала

$ cd /home/kali/Android/Sdk/emulator - позиционирање у фолдер где се налази емулатор

$ ./emulator -list-avds - излиставање свих емулираних уређаја

$ ./emulator -avd <naziv> - покретање једног помоћу његовог назива

Процес форензичке истраге



Напомена – етапе форензичке истраге не одвијају се секвенцијално. Често су репетитивне.

Прикупљање

Идентификоване доказе је потребно прикупити коришћењем научно и правно ваљаних метода.

Прављење форензичке копије SIM картице, SD картице, интерног складишта мобилног уређаја.

Потребно је припремити медије на којима се прави форензичка копија.

Опрема:

- ➔ Фарадејева врећа
- ➔ USB keep-alive dongle
- ➔ Читачи SD картица
- ➔ SIM клонер
- ➔ Каблови и адаптери

Прикупљање

Припрема и изоловање



USB keep-alive dongle



Фарадејева врећа



Клонер SIM картица

Прикупљање

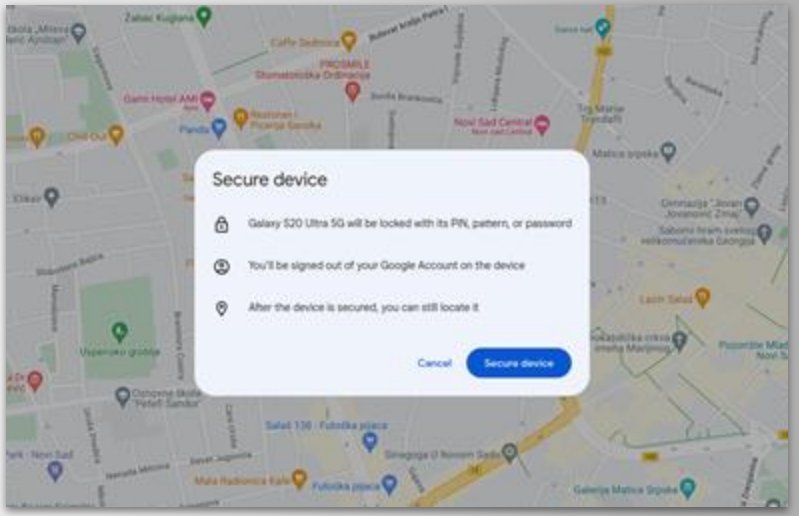
Припрема и изоловање

- Овлашћења (правна надлежност)
- Тренутно стање уређаја (разбијен екран, закључан, угашен)
- Битни/тражени подаци за истрагу
- Идентификација других потенцијалних извора доказа: SD, SIM, отисци прситију, сигурносне копије података у облаку.
- Повезати уређај на извор напајања.
- Мрежно изоловати уређај (фарадејева врећа, авионски режим, мрежно изоловане лабораторије)
- Онеспособити закључавање уређаја (хардверска и софтверска решења)

Прикупљање

Откључавање мобилних уређаја

- Реконстуркција или погађање кода, обрасца, лозинке (брут-форс напади, dictionary напади, pattern guessing).
- Промена конфигурационих датотека или брисање датотека са подацима за аутентификацију (ако је приступ интерном складишту података омогућен).
- Примена специјалних софтверских алата (често није могућа са новијим верзијама Androida и iOS-a)



Google Find My Device

Закључавање помоћу мрежних сервиса (Google, Samsung..) може да отежа истрагу.

Прикупљање


Методе екстракције података
РУЧНО ПРИКУПЉАЊЕ
ЛОГИЧКО ПРИКУПЉАЊЕ
ФИЗИЧКО ПРИКУПЉАЊЕ
ПРИКУПЉАЊЕ ИЗ ОБЛАКА
ПРИКУПЉАЊЕ ИЗ ЦЕЛУЛАРНЕ МРЕЖЕ

Ручно прикупљање

- Прикупљање коришћењем корисничког интерфејса мобилног уређаја.
- Докази се прикупљају на највишем нивоу апстракције.
- Приступамо само оним подацима које нам ОС дозвољава да прегледамо.
- Услов: да је уређај функционалан и отључан.
- Неопходно је да снимимо процес.
- Једноставно је интерпретирати податке.
- Поступак може да промени стање уређаја.

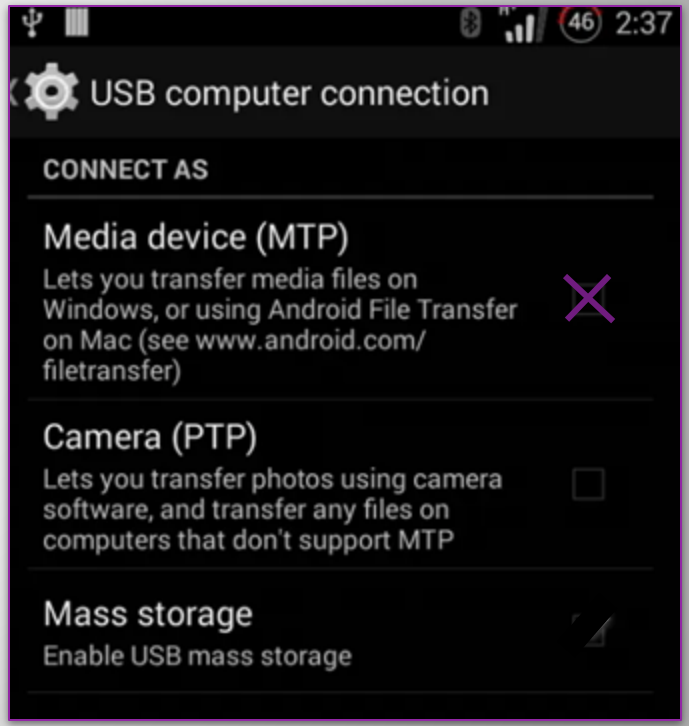
Логичко прикупљање

Media Transfer Protocol (MTP)

1. Потребно је повезати рачунар и мобилни уређај USB каблом
2. Пребацити уређај у „мод за пренос мултимедијалног садржаја" или „мод за пренос фотографија"
3. Добићемо приступ фолдерима, чији садржај је могуће преузети:

   /sdcard/DCIM

   /sccard/Pictures

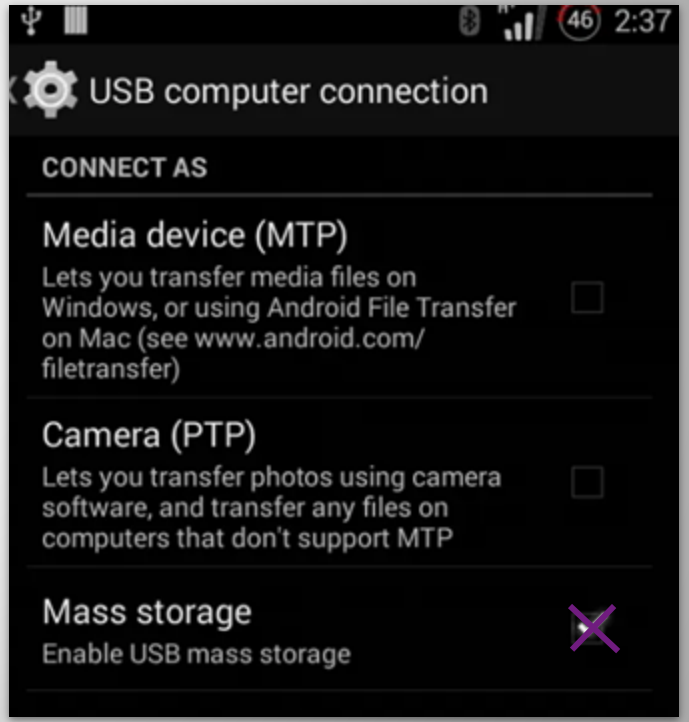


Логичко прикупљање

USB Mass Storage (UMS)

1. Потребно је повезати рачунар и мобилни уређај USB каблом
2. Пребацити уређај у „мод за пренос датотека"
3. Добићемо приступ само једном делу интерног складишта података

/sdcard



Логичко прикупљање



Android Debugging Bridge (ADB)

Софтверски алат за комуникацију са Android уређајима.
Служи углавном за отклањање грешака на Android уређајима приликом програмирања.

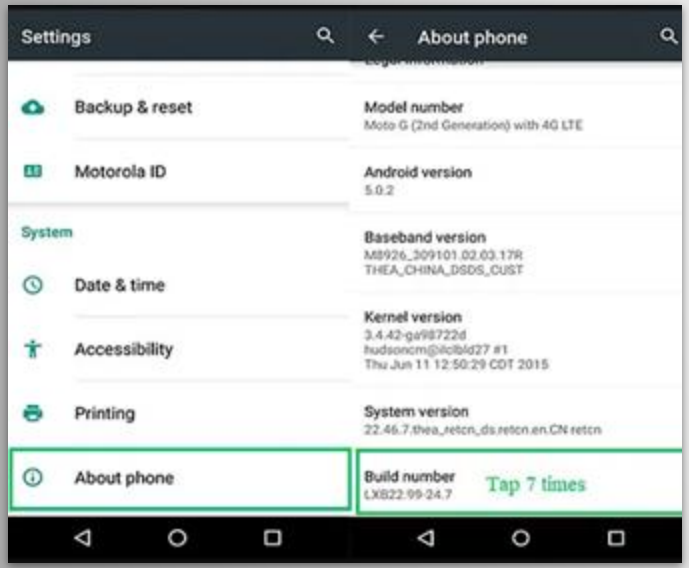
1. Потребно је омогућити “Опције програмера” (енг. Developer options)
2. Потребно је укључити „USB проналажење грешака“ (енг. USB debugging)
3. Потребно је повезати рачунар и мобилни уређај USB каблом
4. Пребацити уређај у „мод за пренос датотека"
5. Потребно је ауторизовати USB проналажење грешака.
6. Могуће је из терминала уносом команди преузети податке са уређаја.

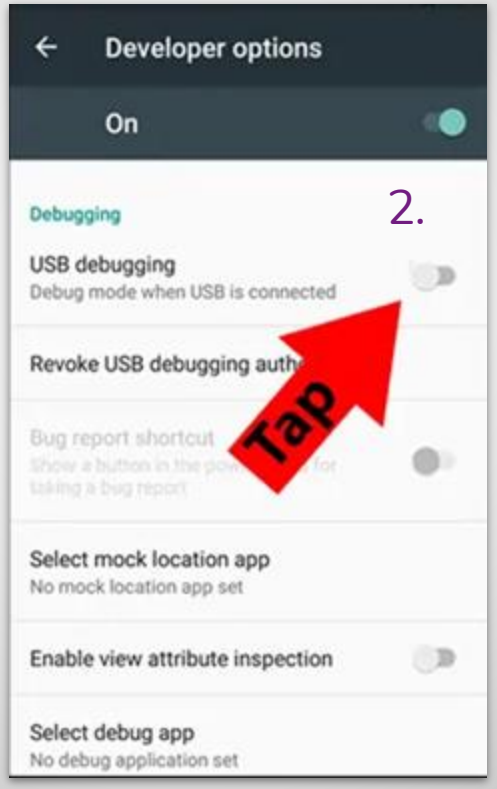
   Да бисмо могли да преузмемо цело складиште података потребан је **root** приступ.

Логичко прикупљање

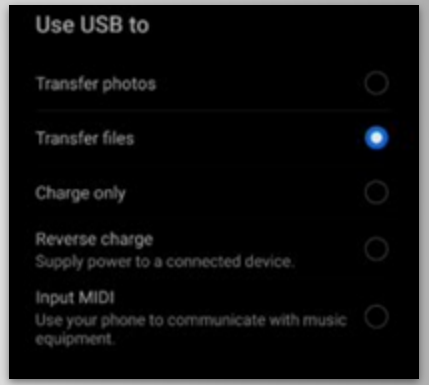
Android Debugging Bridge (ADB)

1.

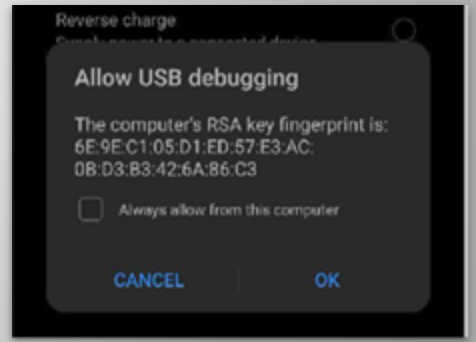




4.



5.



Логичко прикупљање



Android Debugging Bridge (ADB)

Да бисмо добили листу повезаних мобилних уређаја који су повезани на рачунар користимо следећу команду: **$ adb devices**

Помоћу наредне команде можемо приступити интерном складишту података преко терминала на рачунару и прегледати га: **$ adb shell** и **$ exit**

Приказ информација о доступном, искоришћеном и укупном простору на уређају можемо добити помоћу команде disk free (df): **$ [adb shell] df**

Листу апликација које су инсталиране можемо добити командом: **$ adb shell pm list packages**

Да бисмо преузели цело или део интерног складишта података користимо следећу команду: **$ adb pull [source path] [destination path]**

Логичко прикупљање



Android Debugging Bridge (ADB)

У оквиру ADB-а постоји **dumpsys** команда која пружа информације о системским услугама које се користе (није потребан root приступ), а које нам могу дати корисне информације.
Можемо добити информације о RAM меморији, батерији, дијагностици мреже, итд.
Покреће се над тренутно повезаним уређајем.

Листа свих активних системских услуга: **$ adb shell dumpsys [-l]**

$ adb shell dumpsys **procstats --hours 3**
$ adb shell dumpsys **batterystats**
$ adb shell dumpsys **netstats detail**
$ adb shell dumpsys **backup**
$ adb shell dumpsys **wifi**

Остале команде могу се наћи на линку.

Логичко прикупљање



Content Providers

Могуће је добити одређене информације о добављачима садржаја (енг. Content Providers) помоћу ADB алата, помоћу команде:

$ adb shell dumpsys package providers

AF Logical OSE - Android форензичка апликација и оквир отвореног кода. Омогућава испитивачу да издвоји позиве из евиденције позива, телефоне контаката, MMS поруке и SMS поруке са Android уређаја

Инсталирати апликацију на телефон командом

$ adb install AFLogical-OSE_1.5.2.apk

Преузети податке са телефона на рачунар командом

$ adb pull /sdcard/forensics/ [destination]

Логичко прикупљање

Backup

Сигурносне копије података (енг. backup) - могу бити ускладиштене на SD картици, на PC рачунарима повезаним са мобилним уређајем или у облаку. Обично су шифроване.

Може им се приступити коришћењем стандардних софтверских алата за рад са сигурносним копијама или специјализованим форензичким алатима уз познавање криптографског кључа.

Могуће је помоћу ADB-а направити сигурносне копије података које не захтевају root приступ и помоћу одређених алата за рад са сигурносним копијама прегледати садржај.

Логичко прикупљање

Backup

Команда за прављење сигурносне копије је следећа:

$ adb backup [-f <file>] [-apk|-noapk] [-shared|-noshared] [-all] [-system|-nosystem] [<packages...>]

- -f : путања *.ab датотеке која ће бити сачувана на рачунару.
- -apk|-noapk : означава да ли треба направити резервну копију *.apk датотека (default is -noapk)
- -obb|-noobb :омогући/онемогући резервну копију било које инсталиране apk датотеке повезане са сваком апликацијом (default is -noobb)
- -shared|-noshared: омогући/онемогући резервну копију дељене меморије уређаја, садржаја SD картице (default is -noshared)
- -all : означава да желите да направите резервну копију целог система. Можете користити филтер пакета само да направите резервну копију одређених пакета или користите -all за потпуну резервну копију система.
- -system|-nosystem: показује да ли су све системске апликације и подаци укључени приликом прављења резервне копије. (default is -system)
- <packages> : овде можете навести одређене пакете за резервну копију. Користите их ако желите да направите резервну копију само одређених апликација. Ако користите -all, не морате да наводите пакете.

Пример: **$ adb backup -apk -shared -all -nosystem -f backup.ab**

Биће тражено на уређају да унесете лозинку (користи се због шифровања резервне копије)

Логичко прикупљање



MOBILedit алат

MOBILedit софтверски алат за форнзику мобилних уређаја. Служи за екстракцију података са телефона, паметних сатова, из облака.

Користи и физичко и логичко прикупљање података.

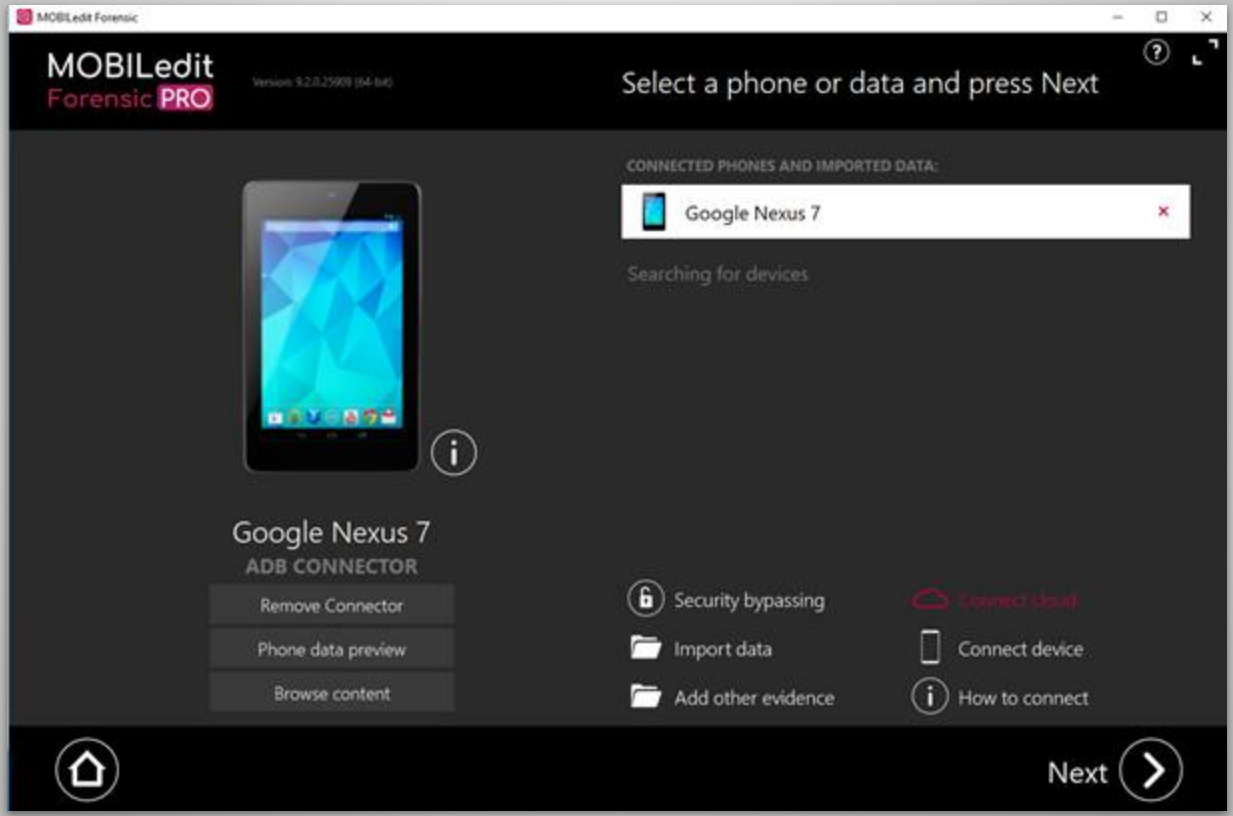
Може да анализира мобилне апликације, врши опоравак избрисаних података, има широк спектар подржаних уређаја, може да генерише извештаје.

Документација https://forensic.manuals.mobiledit.com/MM/

Видео снимци https://content.mobiledit.com/training/

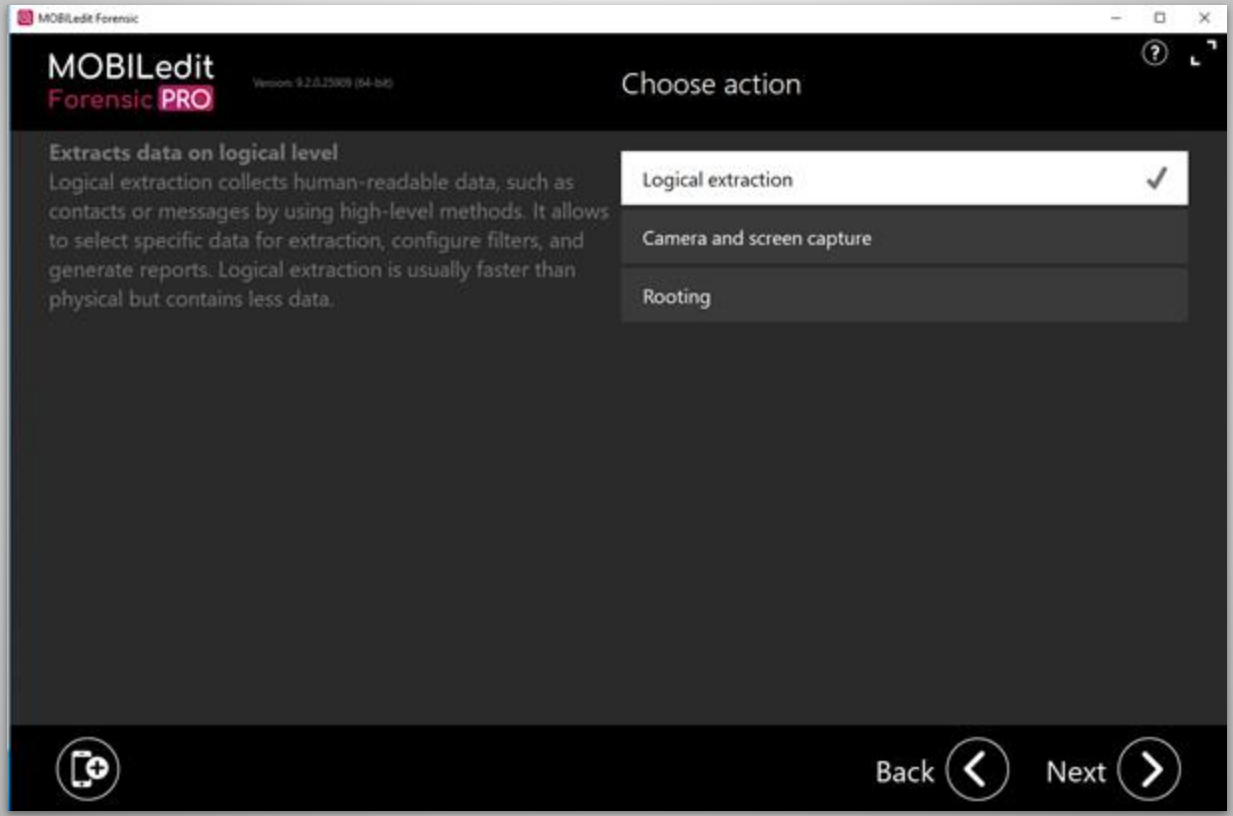
Логичко прикупљање

MOBILedit алат



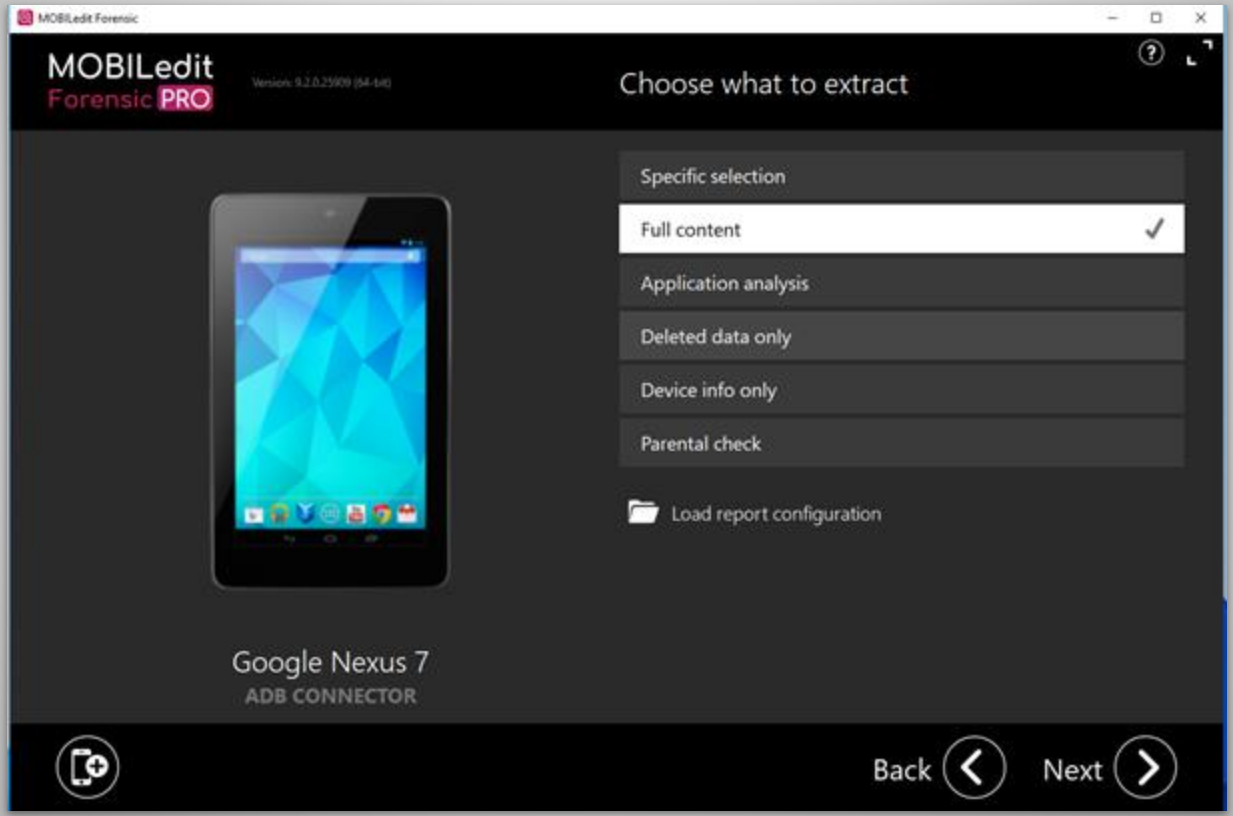
Логичко прикупљање

MOBILedit алат



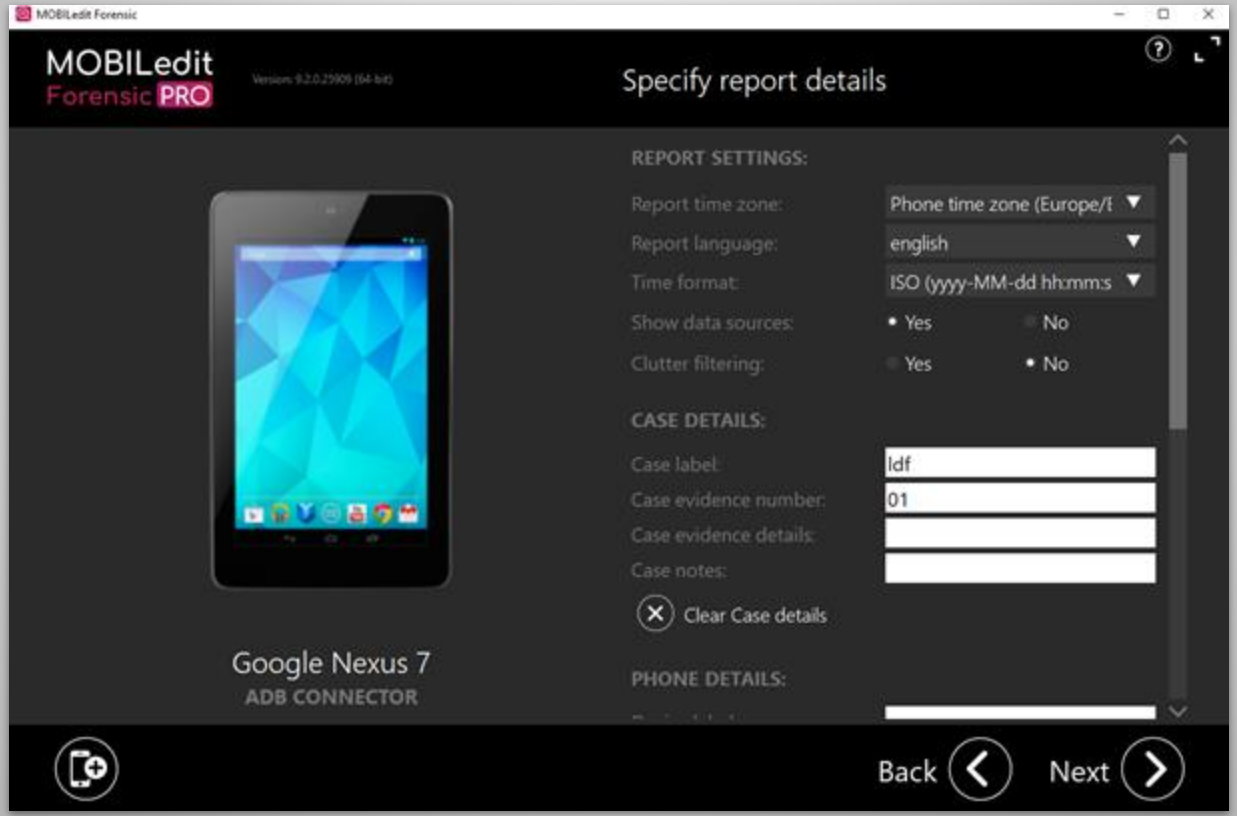
Логичко прикупљање

MOBILedit алат



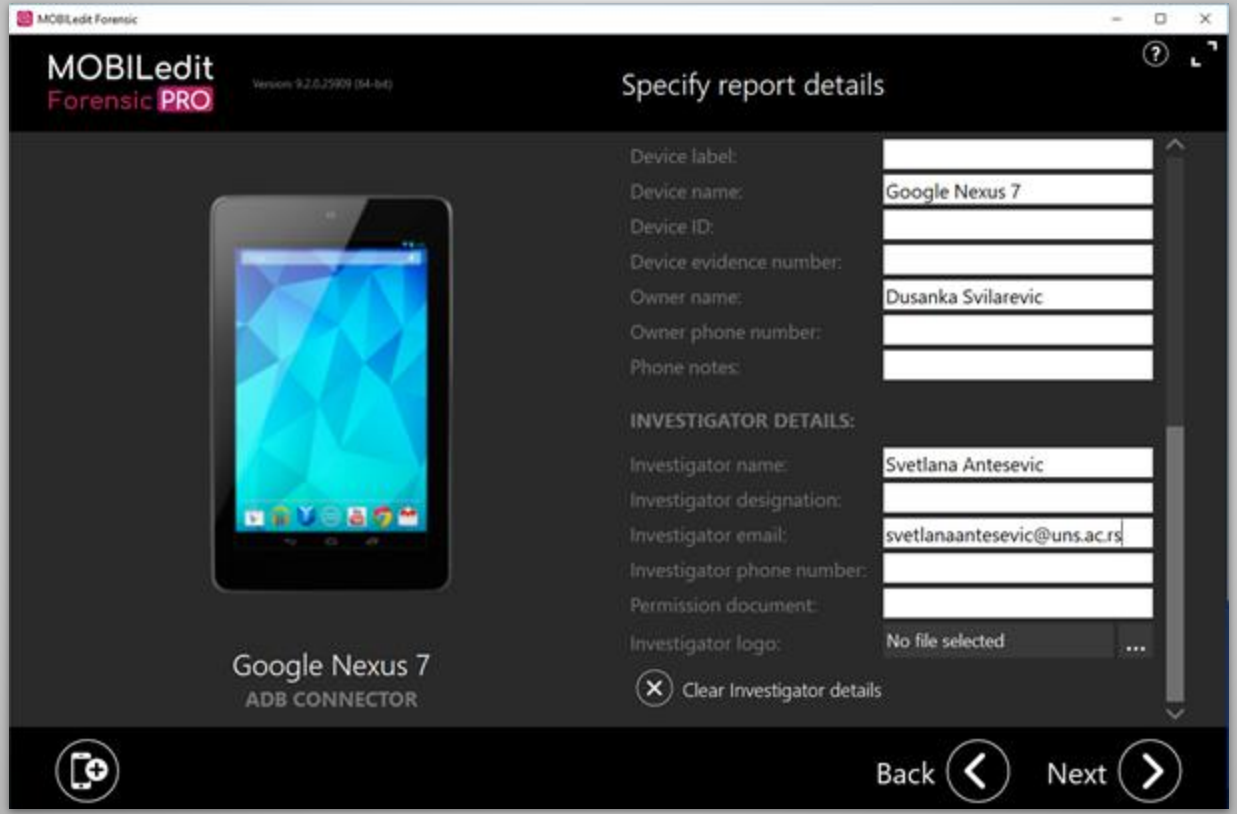
Логичко прикупљање

MOBILedit алат



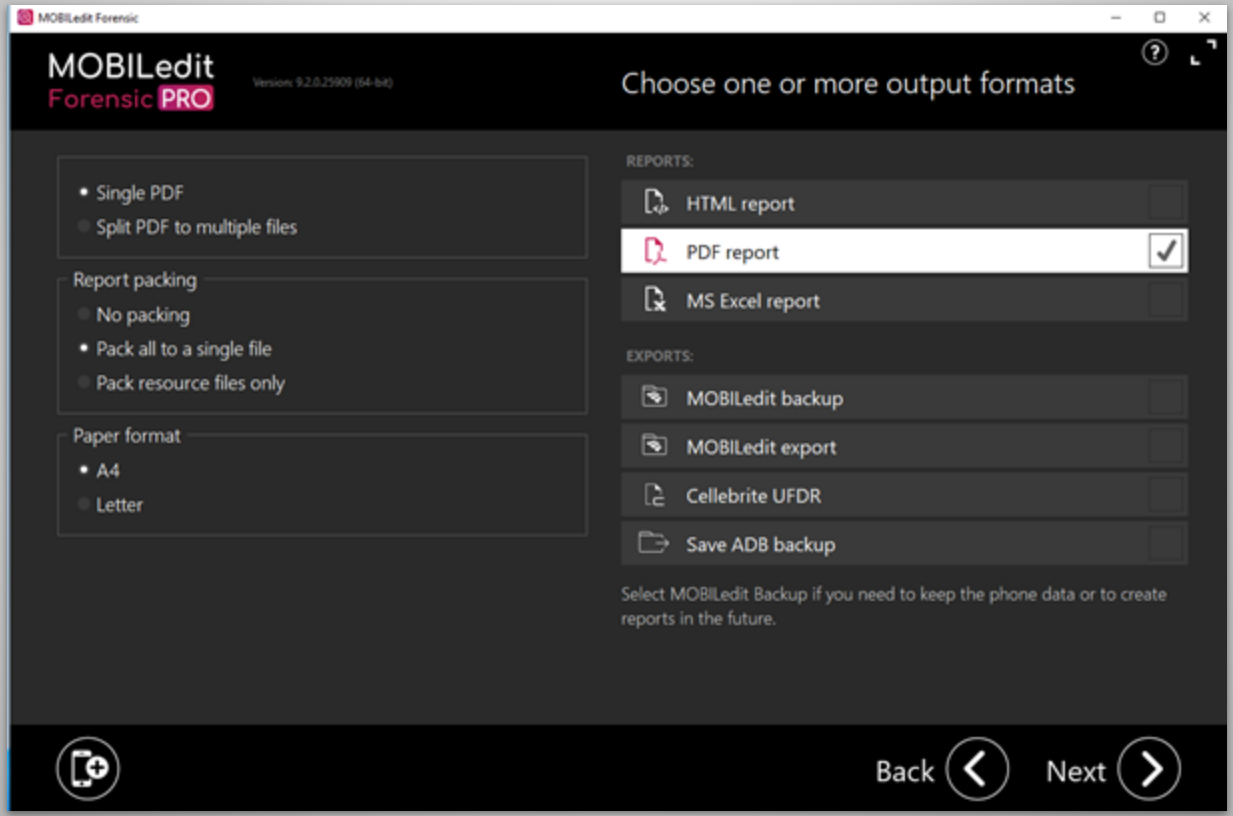
Логичко прикупљање

MOBILedit алат



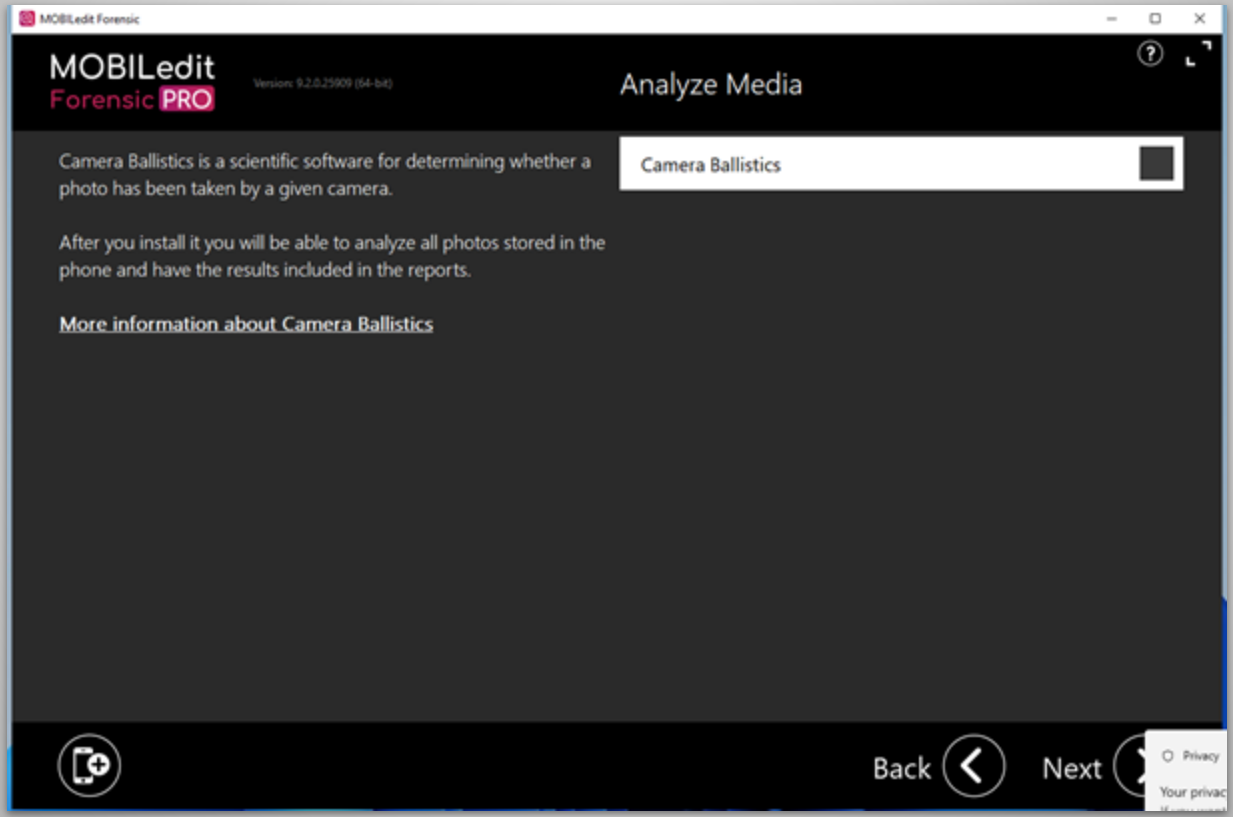
Логичко прикупљање

MOBILedit алат



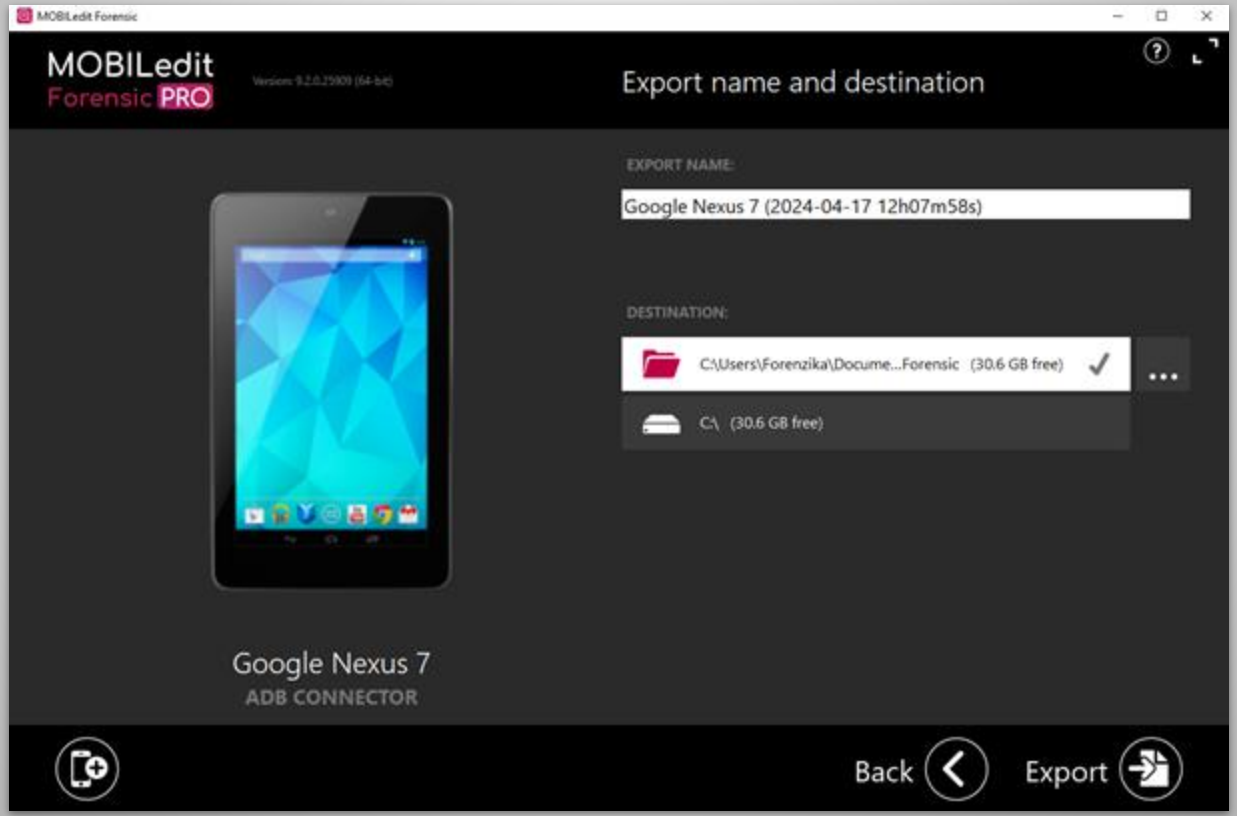
Логичко прикупљање

MOBILedit алат



Логичко прикупљање

MOBILedit алат



Логичко прикупљање

MOBILedit алат



Логичко прикупљање

Secure Digital (SD)

Меморијске картице (енг. Secure Digital - SD) користе преносни уређаји: фотоапарати, камере, паметни телефони..

Постоје различите класе и физичке димензије: standard, mini, micro.

Ако су подаци ускладиштени на SD картици и нису шифровани, могуће их је прикупити читачем SD картица.

Новији модели SD могу да шифрују податке.





Логичко прикупљање

Rooting

- Рутовање (енг. rooting) је процес стицања привилегованог приступа на Android уређају.
- Root приступ уређају омогућава приступ партицијама и директоријумима којима се не може приступити преко UMS, MTP, ADB.
- Метод за преузимање целог интерног складишта података искоришћавањем рањивости оперативног система са циљем да се добије root приступ уређају.
- Конкретне рањивости које се могу искористити у великој мери зависе од верзије ОС.

Booting

- Boot-овање - други метод за преузимање целог интерног складишта података је учитавање наменског оперативног система уместо Android-а или iOS-а.
- Наменски оперативни систем омогућава директан приступ складишту података и партицијама.
- Учитавање наменског оперативног система није могуће ако уређај користи безбедно учитавање оперативног система.



Физичко прикупљање



In-System Programming (ISP)



Chip Off



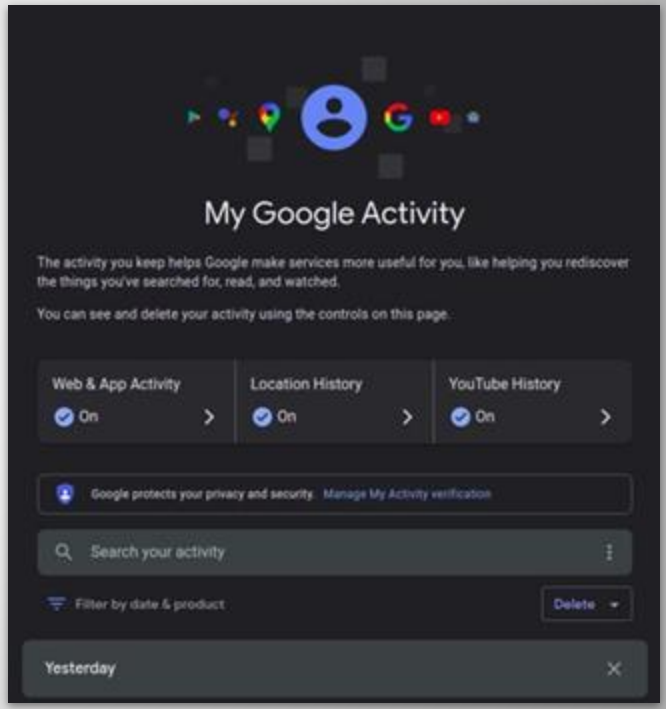
JTAG

Прикупљање из облака

Неки докази могу бити ускладиштени у облаку тј. на неком серверу на интернету.

Google, Apple, Huawei нуде мрежне сервисе који омогућавају синхронизацију података између два мобилна уређаја или мобилног уређаја и рачунара.

Уз познавање корисничког имена и лозинке могуће је приступити тим сервисима и преузети податке.



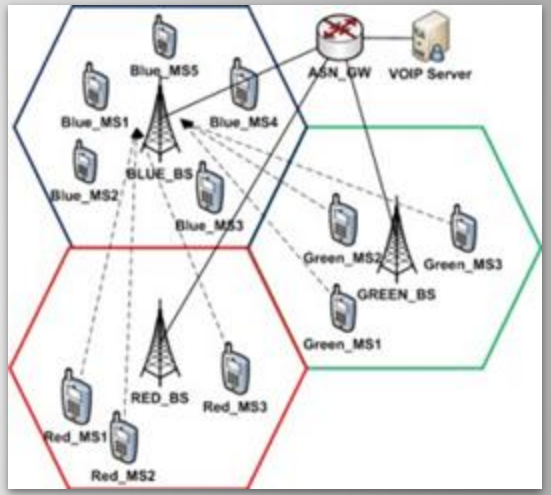
Прикупљање из целуларне мреже

Могуће добити од телекомуникационих оператора уз наредбу суда, задржане податке Call Detail Record (CDR).

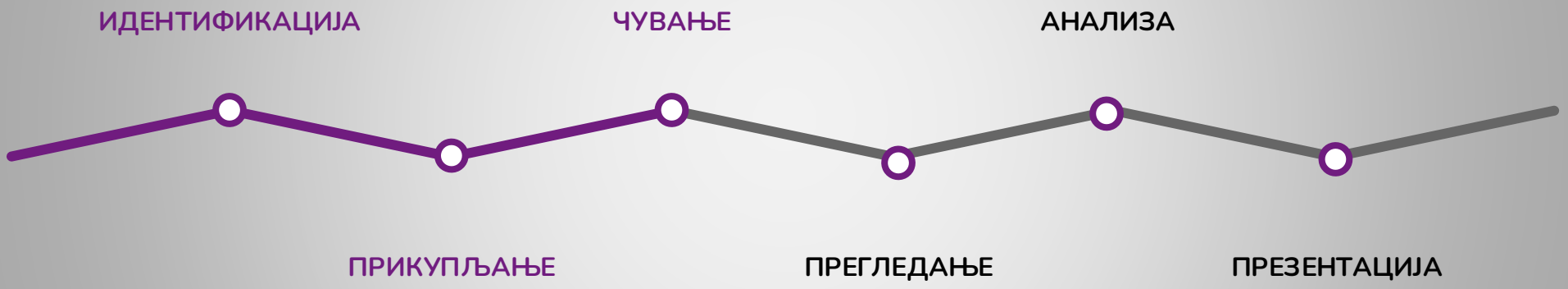
На основу задржаних података је могуће реконструисати комуникације између претплатника, локације претплатника, али не и садржај комуникације.

Могуће је клонирати SIM картицу помоћу клонера SIM картица и прикупити потенцијалне податке: сачувани контакти, позиви, поруке..

Закон о електронским комуникацијама



Процес форензичке истраге



Напомена – етапе форензичке истраге не одвијају се секвенцијално. Често су репетитивне.

Чување

Прикупљени докази морају се сачувати коришћењем физичких, техничких и организационих контрола.

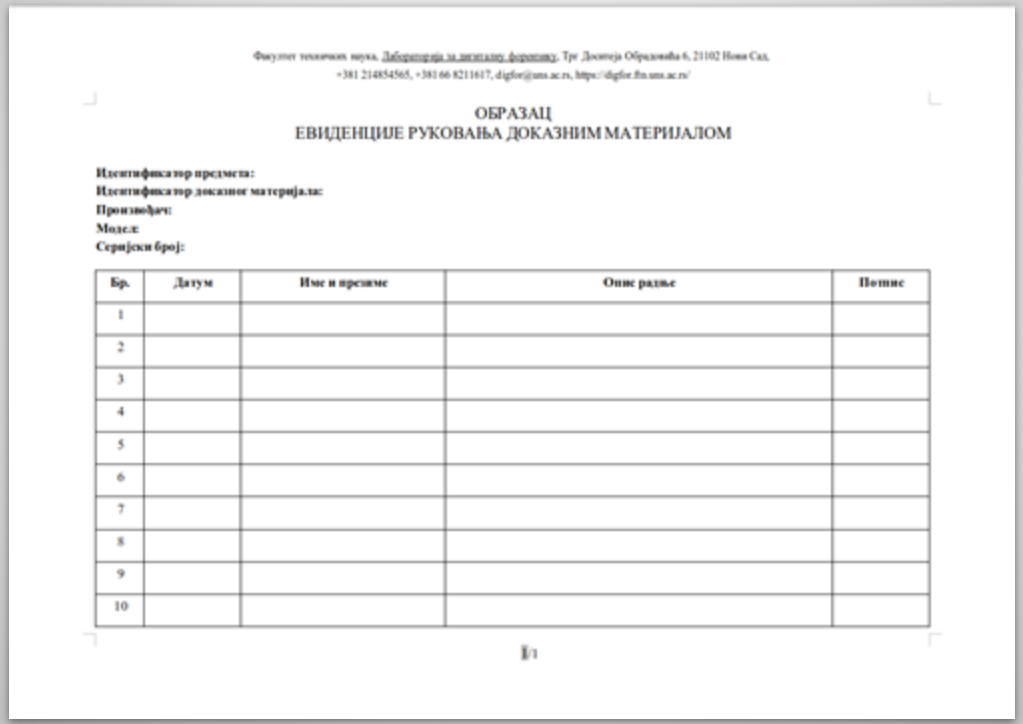
Верификација прикупљених података спроводи се помоћу рачунања хеш вредности (са неким од алгоритама: sha1, sha256, md5) да би се обезбедио интегритет доказа.

Рачунање хеш вредности:

- ➔ MD5 алгоритам: **$ [sudo] md5sum [path]**
- ➔ SHA1 алгоритам: **$ [sudo] sha1sum [path]**

Чување

Ланац доказа - евиденција о томе када и ко је имао приступ доказима.



Факултет техничких наука, Лабораторија за дигиталну форензику, Трг Доситеја Обрадовића 6, 21102 Нови Сад,
+381 214854565, +381 66 8211617, digfor@uns.ac.rs, https://digfor.ftn.uns.ac.rs/

ОБРАЗАЦ
ЕВИДЕНЦИЈЕ РУКОВАЊА ДОКАЗНИМ МАТЕРИЈАЛОМ

Идентификатор предмета:
Идентификатор доказног материјала:
Произвођач:
Модел:
Серијски број:

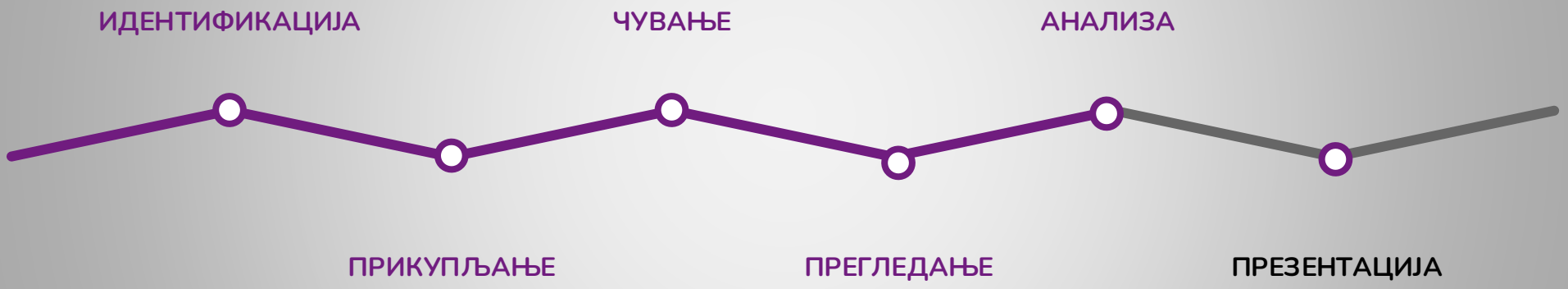
Бр.	Датум	Име и презиме	Опис радње	Потпис
1				
2				
3				
4				
5				
6				
7				
8				
9				
10				

Чување

Докази се чувају у одговарајућем формату датотека који омогућавају компресију података, поделу датотека на више датотека и шифровање датотека.

- ➔ XRY - власнички формат датотека (XRY)
- ➔ DD, ISO - сирови формати датотека
- ➔ AB - формат сигурносне копије направљене помоћу ADB-а

Процес форензичке истраге



Напомена – етапе форензичке истраге не одвијају се секвенцијално. Често су репетитивне.

Прегледање и анализа

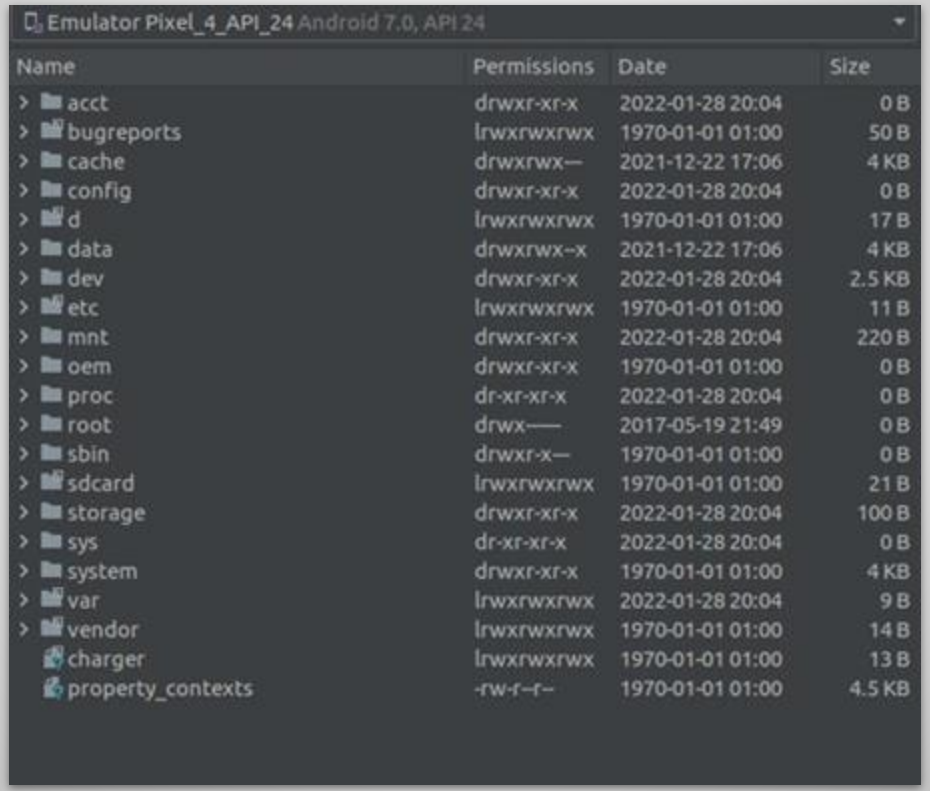
Android partition layout

Изглед партиција варира између произвођача и верзија, али неколико партиција је присутно на свим Android уређајима

```
1|generic_x86:/ $ svetlana@svetlana:~$ adb shell
generic_x86:/ $ df -h
Filesystem      Size  Used Avail Use% Mounted on
tmpfs           757M  460K  757M   1% /dev
tmpfs           757M     0  757M   0% /mnt
/dev/block/vda  1.9G  1.6G  244M  88% /system
/dev/block/vdb   61M   68K   60M   1% /cache
tmpfs           757M     0  757M   0% /storage
/dev/block/dm-0 5.8G  1.1G  4.6G  20% /data
/dev/fuse       5.8G  1.1G  4.6G  20% /storage/emulated
/dev/fuse       510M   88K  510M   1% /storage/160E-1716
svetlana@svetlana:~$
```

Прегледање и анализа

Android file hierarchy



Прегледање и анализа

Autopsy & The Sleuth Kit

Припрема и екстракција потенцијалних доказа из прикупљених извора података.

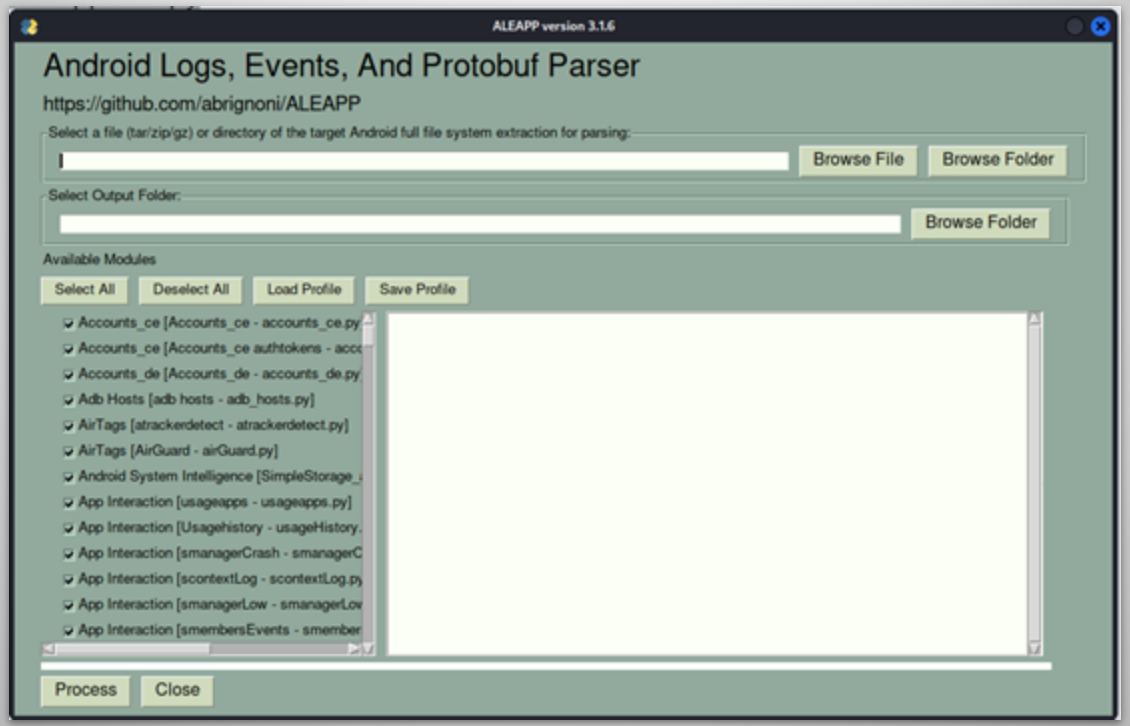
Autopsy модули за преглед података са мобилних уређаја:

- ➔ **aLeapp** модул везан за преглед података прикупљених са Android телефона
- ➔ **iLeapp** модул везан за преглед података прикупљених са iOS телефона.

Прегледање и анализа

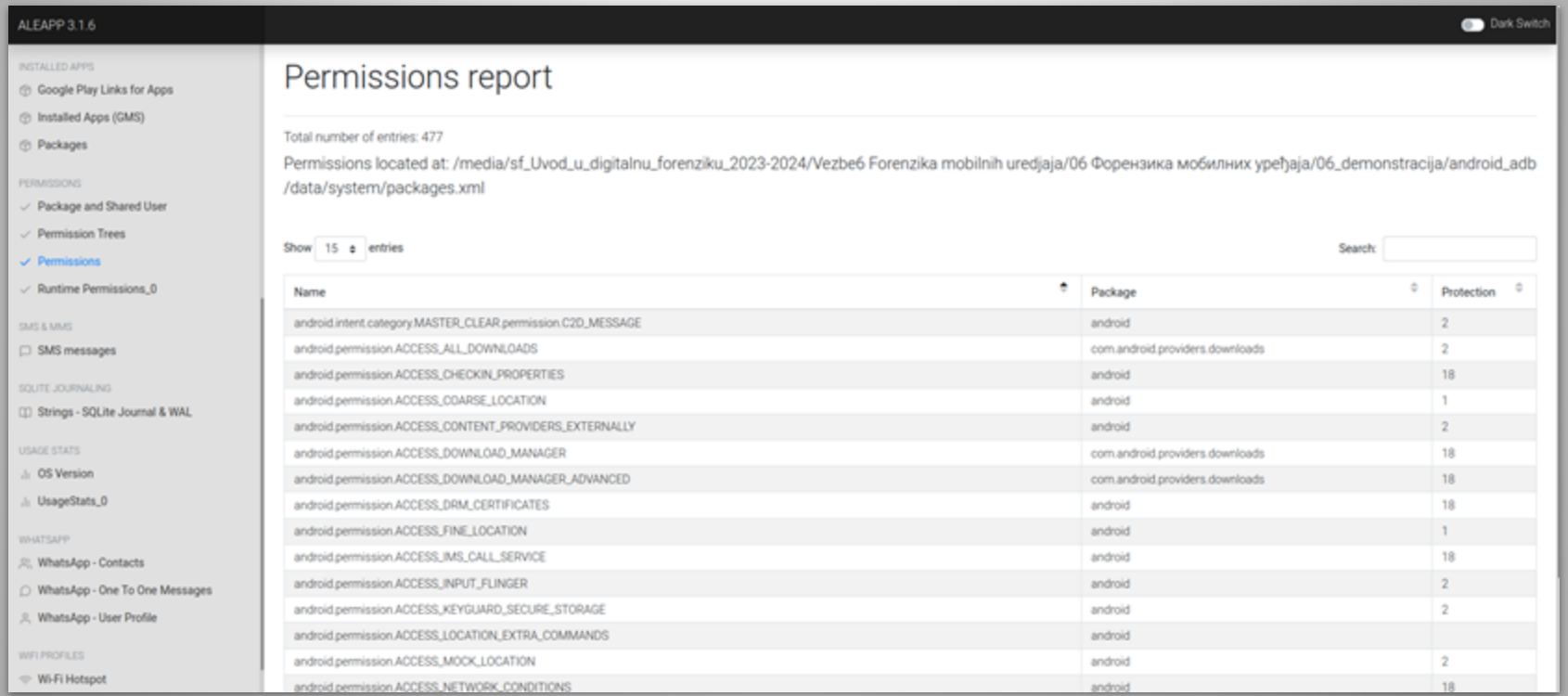
ALEAPP 3.1.6 - Android Logs Events And Protobuf Parser

$ python /opt/ALEAPP-3.1.6/aleappGUI.py



Прегледање и анализа

ALEAPP 3.1.6 - Android Logs Events And Protobuf Parser



Прегледање и анализа



DB Browser for SQLite

Софтверски алат који служи за прегледање и анализу SQLite база података.

Омогућава да истражите датотеке базе података са следећим екстензијама: .sqlite, .sqlite3, .sqlitedb, .db, и .db3.

Подаци се углавном налазе у оквиру **/data/data** секције код мобилних уређаја.

Примери:

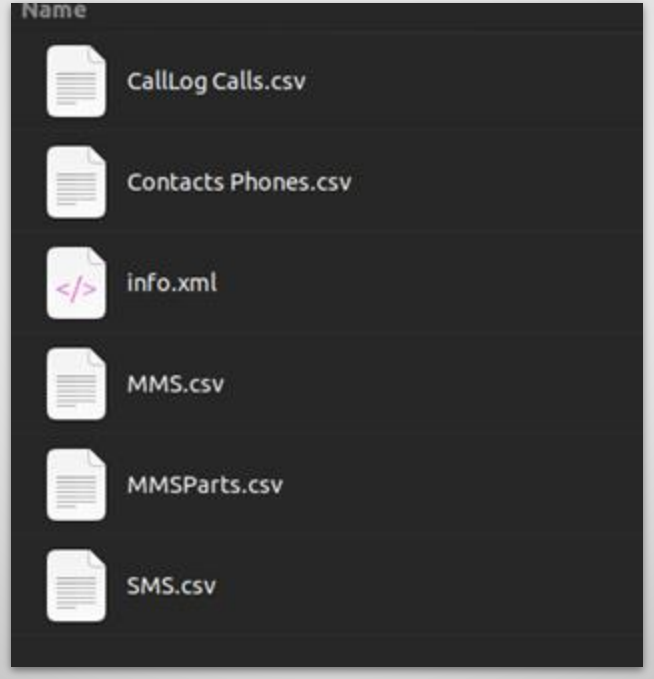
/android_adb/data/data/com.whatsapp/databases/msgstore.db

/android_adb/data/data/com.google.android.gm/databases/mailstore.<user-email>.db

Прегледање и анализа

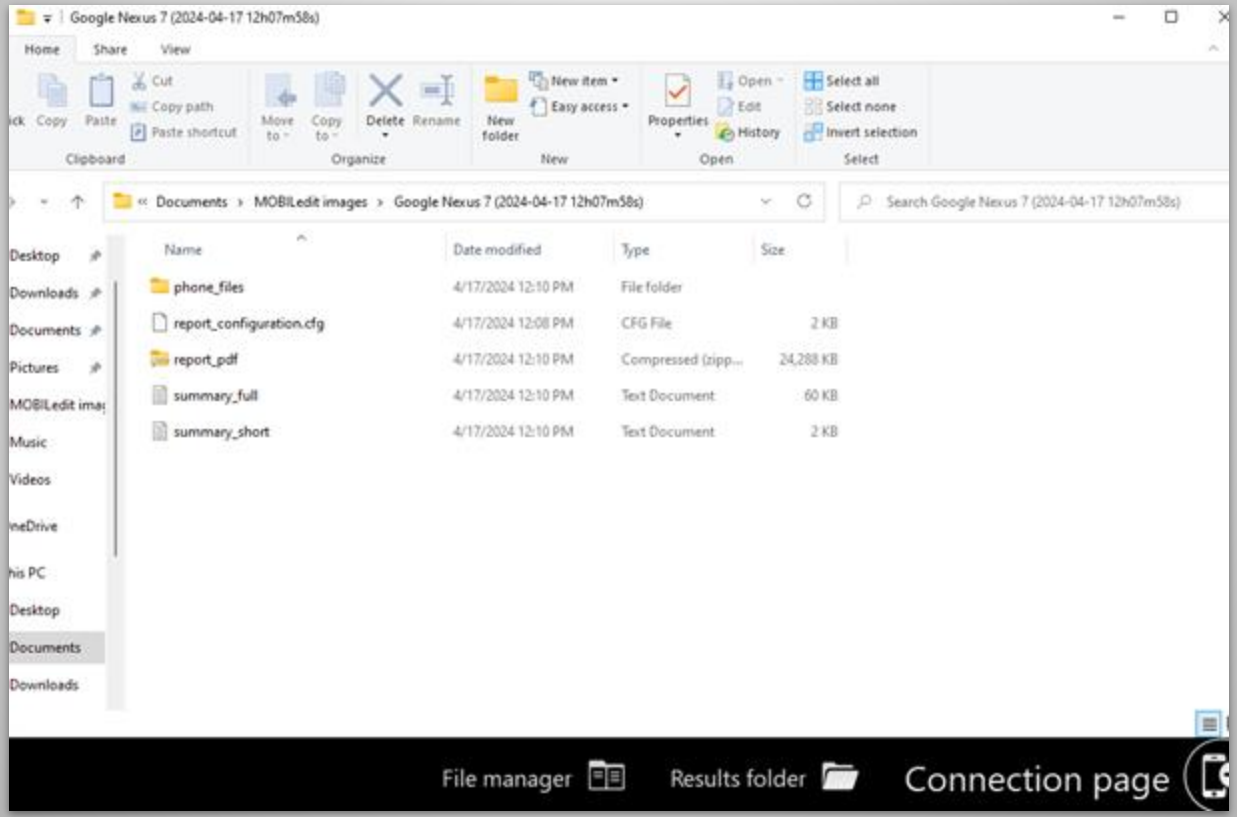
AFLogical OSE

Прегледање и анализа .csv датотека добијених помоћу **AFLogical OSE** алата помоћу LibreOffice Calc софтвера.



Прегледање и анализа

MOBILedit



Прегледање и анализа

MOBILedit



MOBILedit Forensic

MOBILEDIT FORENSIC PHONE CONTENT REPORT

ldf

Case Evidence Number: **01**

Manufacturer	Google
Product	Nexus 7
HW Revision	LMY47V
Platform	Android
SW Revision	5.1.1 (22)
Serial Number	015d2ea4ab441a0f
Adb Backup Password	12345678
Rooted	No
SIM Card	No

Case Information

Case Label	ldf
Case Evidence Number	01
Case Evidence Details	

Device Information

Device Label	
Device Name	Google Nexus 7
Device ID	
Device Evidence Number	
Owner Name	Dusanka Svilarevic
Owner Phone Number	
Phone Notes	

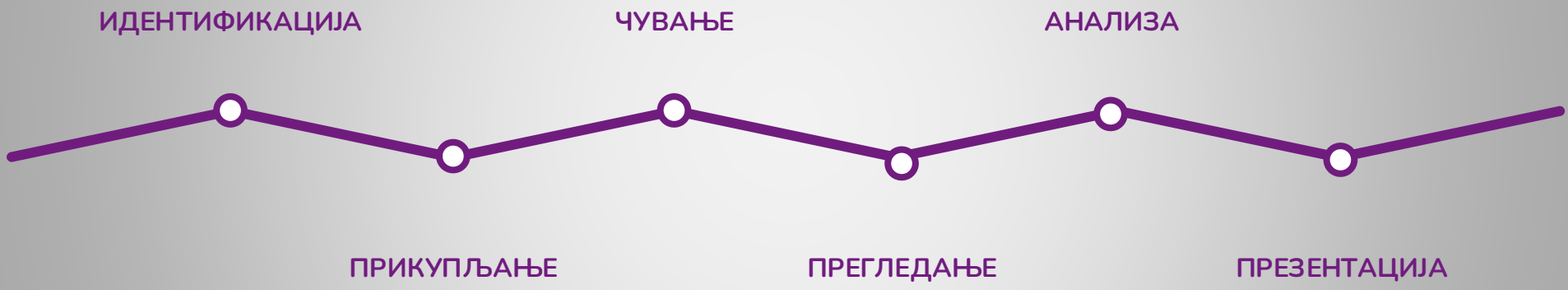
Investigator Information

Investigator Name	Svetlana Antesevic
Investigator Designation	
Investigator Email	svetlanaantesevic@uns.ac.rs
Investigator Phone Number	
Permission Document	

Extraction Information

Data Extraction Started	2024-04-17 12:08:38 (UTC-7)
Data Extraction Finished	2024-04-17 12:10:25 (UTC-7)
Extracted by	MOBILedit Forensic PRO 9.2.0.25909
Report Generated by	MOBILedit Forensic PRO 9.2.0.25909
Client Application	Forensic Connector 1.10.8-29457(F)

Процес форензичке истраге



Напомена – етапе форензичке истраге не одвијају се секвенцијално. Често су репетитивне.

Презентација

Резултати анализе доказа се презентују у писменом облику.

Односи се на процес којим форензичар дели резултате фазе анализе у облику извештаја заинтересованим странама.

Форензичар обично сачињава налаз и мишљење и усмено га брани одговарајући на питања на главном судском претресу.

Корисни линкови и књиге

Линкови:

- https://www.kali.org/docs/
- https://github.com/abrignoni/ALEAPP
- https://github.com/den4uk/andriller
- https://developer.android.com/studio
- https://sqlitebrowser.org/
- https://www.mobiledit.com/

Књиге:

- *Digital Forensics with Kali Linux*
- *Digital forensics : an academic introduction*
- *Learning Android Forensics*
- *Learning iOS Forensics*
- *Practical Mobile Forensics*

